

王亚林主题分享：腾讯办公网智能体安全治理方案

王亚林（主讲）

Codex（整理）

2026 年 6 月 6 日



视频作者/频道：指尖安全 / 2026 腾讯云 AI 产业应用大会

发布日期：2026 年 6 月 5 日

视频时长：专题片段 18 分 02 秒（01:33:10-01:51:12）

视频链接：<https://www.bilibili.com/video/BV1xz7C67E2t/>

PDF 制作 Skill：<https://github.com/wdkns/wdkns-skills>

目录

1 导读：办公网智能体安全的问题重心	3
1.1 关键术语	3
1.2 本章小结	4
2 从访问控制到行动链：安全边界怎样变化	4
2.1 三阶段演进	5
2.2 用公式描述链式风险	5
2.3 本章小结	5
3 治理五问：把抽象风险变成可问责对象	6
3.1 五个问题	7
3.2 形式化理解：一次 Agent 行动事件	7
3.3 五问与办公网资产盘点	8
3.4 本章小结	8
4 腾讯 IOA 三层治理闭环	8
4.1 第一层：事前准入	9
4.2 第二层：事中控制	9
4.3 第三层：事后溯源	10
4.4 三层闭环图	10
4.5 本章小结	10
5 实践案例：一次 AI Agent 风险事件怎样被发现、阻断和追溯	10
5.1 事件链路	11
5.2 为什么敏感数据场景更难	11
5.3 本章小结	12
6 30 天落地路线：从可见到可治理	12
6.1 0-10 天：先看得见	12
6.2 11-20 天：再管得住	13
6.3 21-30 天：最后追得回	13
6.4 容易漏掉的未知问题	13
6.5 本章小结	13
7 总结与延伸	13

7.1	演讲核心压缩	14
7.2	对企业安全团队的启发	14
7.3	下一步检查清单	14
7.4	最终小结	15

1 导读：办公网智能体安全的问题重心

这场分享讨论的是企业办公网中的 AI Agent 治理。办公网的特殊性在于，它连接员工、终端、账号、业务系统、代码、文档、凭据、外发通道和审计体系。Agent 进入办公网以后，安全团队面对的对象从一次普通访问扩展成一条被授权的行动链：员工提出任务，Agent 解析意图，工具和插件调用 MCP、API、脚本、Shell、剪贴板或文件系统，最后把结果写入系统、传到外部服务，或触达敏感数据。



图 1: 王亚林分享的题目页：腾讯办公网智能体安全治理方案-IOA。¹

主问题

办公网 Agent 安全的核心问题可以压缩成一句话：企业怎样让 Agent 在真实办公环境中可信、可控、可追溯地行动。这里的“行动”指工具调用、数据触达、系统访问、文件处理、命令执行和外发行为组成的连续链路。

用一个偏 Python 的类比会更直观。传统访问控制像给一个用户登录业务系统的权限；Agent 场景更像让一个 Python 脚本在员工电脑上运行，并允许它根据上下文动态 import 包、调用函数、读写文件、访问网络和触发外部 API。安全问题因此从“用户能否登录”扩展成“这个运行体在什么环境里、继承谁的权限、能调用哪些能力、能碰哪些数据、出事后怎样还原”。

1.1 关键术语

Agent、MCP、DLP、EDR、准入与审计

Agent 指能够把目标拆解为步骤并调用工具完成任务的软件执行体。**MCP** 可以理解为把外部工具、数据源和服务暴露给模型或 Agent 的标准化接口。**DLP** 是数据防泄漏体系，重点识别敏感数据和外发行为。**EDR** 是终端检测与响应体系，重点关注进程、命令、文件、网络和威胁活动。**准入** 决定某个身份、终端、应用或 Agent 是否具备进入某个资源边界的资格。**审计**

¹视频画面时间区间：01:34:27-01:34:39。

负责把行为链还原成可解释、可追责、可复盘的证据。

分享的内容可以按四层理解：第一层是安全边界变化，第二层是治理五问，第三层是腾讯 IOA 的三层治理闭环，第四层是实践案例和 30 天落地路线。后文会按这个顺序重构，避免字幕逐句排列。

1.2 本章小结

本章给出整份讲义的阅读入口。办公网 Agent 安全关注的对象是“行动链”，核心目标是可信、可控、可追溯。读者可以先记住三个抓手：身份和环境决定可信，工具和数据决定可控，日志和责任链决定可追溯。

2 从访问控制到行动链：安全边界怎样变化

演讲开头先建立一个对比框架。传统办公网安全主要处理“人访问系统”的问题，链路通常是人、终端、访问链路、应用和数据。防火墙、VPN、访问控制列表、终端准入、账号权限等机制围绕这条链路展开。

Agent 加入以后，链路里多出一个能够代人执行任务的中间层。员工把任务交给 Agent，Agent 再去调用工具、API、MCP 服务、脚本、文档或本地系统。安全边界因此从“保护访问”升级为“保护行动链”。

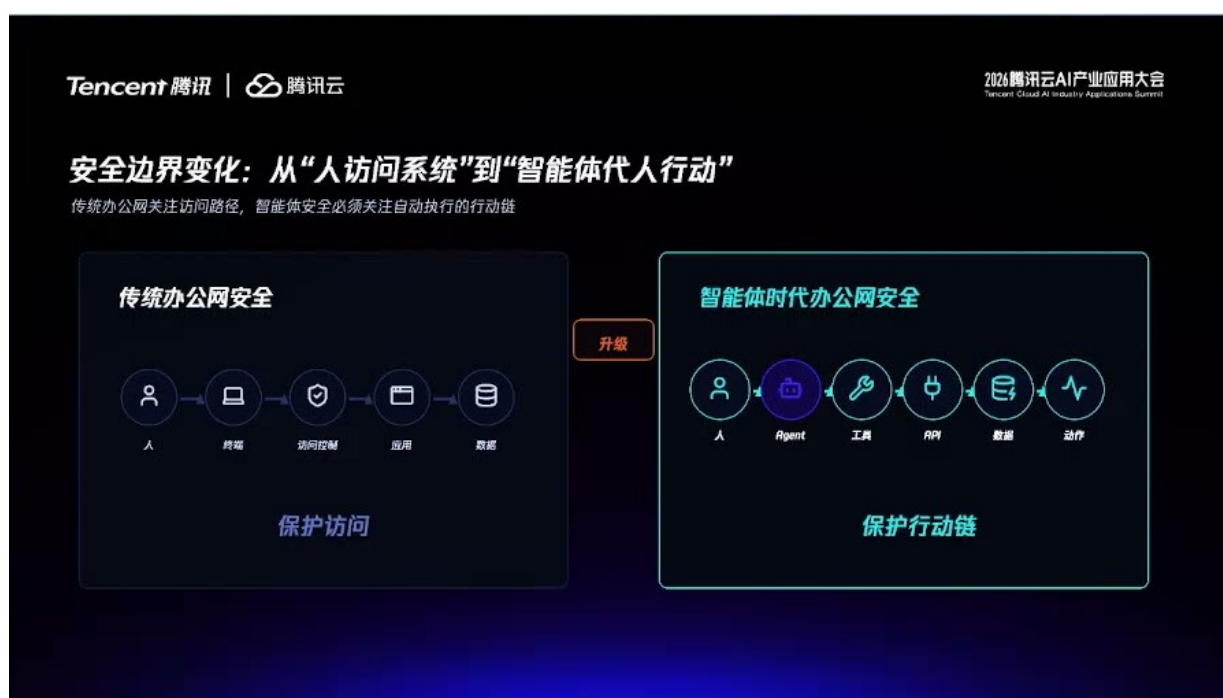


图 2: 安全边界变化：从传统办公网访问路径转向智能体时代的办公网行动链。²

² 视频画面时间区间：01:36:27–01:37:14。

2.1 三阶段演进

第一阶段是生成式 AI 工具。员工把问题、材料或文本交给模型，模型返回问答、摘要或文档草稿。此时安全焦点集中在输入输出内容、账号、网页访问和数据外发。

第二阶段是 IDE 和办公辅助工具。工具开始理解上下文，给出代码修改建议、文档建议或材料整理结果。此时风险增加了一层：工具读取了本地上下文和项目内容，可能接触代码、配置、凭据、内部文档和知识库。

第三阶段是 Agent。Agent 根据任务主动调用工具和服务，访问文件、执行命令、请求 API、触发工作流或调用 MCP。这个阶段的风险来自组合效应。单个步骤看起来可能只是读文件、调接口或生成内容；多个步骤串联起来，就可能形成真实破坏、数据泄漏或越权操作。

常见误判：把 Agent 当成聊天窗口

把 Agent 当成普通聊天窗口会低估风险。聊天窗口主要处理文本输入输出，Agent 会把文本意图转化成外部动作。一个提示词、一个本地工具、一个文件上传、一个 API Token、一个高权限账号和一个可联网环境组合在一起，风险会沿链路放大。

2.2 用公式描述链式风险

链路型风险有一个直观特点：单点风险不高时，串联以后整体风险仍然可能明显升高。若暂时用独立事件近似，整条链至少出现一次失败的概率可以写成：

$$R_{\text{chain}} = 1 - \prod_{i=1}^n (1 - p_i)$$

- R_{chain} ：整条行动链出现至少一次安全失败的概率。
- n ：行动链中的关键步骤数量，例如提示词输入、工具调用、权限继承、数据访问、外发动作。
- p_i ：第 i 个步骤出现安全失败的概率。
- $\prod_{i=1}^n (1 - p_i)$ ：所有步骤都没有失败的近似概率。

这个公式只是一种教学近似。真实系统中的风险事件常常相关，例如同一个高权限账号会同时放大工具调用和数据访问风险；同一个未治理插件也可能同时影响命令执行、网络访问和日志完整性。它的价值在于提醒安全团队：治理 Agent 时要看链路组合，不能只看孤立控制点。

2.3 本章小结

Agent 时代的办公网安全边界从“人到系统”的访问路径扩展到“人到 Agent 到工具到系统/API 到数据/动作”的行动链。安全团队的控制面也随之扩大：身份、终端、进程、工具、MCP、API、文件、凭据、外发通道和审计日志都进入同一个治理问题。

3 治理五问：把抽象风险变成可问责对象

演讲提出了一个可操作的治理框架：办公网智能体安全治理五问。它的价值在于把抽象的“Agent 风险”拆成五个可以落地的问题。



图 3: 治理框架：办公网智能体安全治理五问。³

³视频画面时间区间：01:38:32–01:40:01。

3.1 五个问题

治理问题	对应对象	安全含义
谁在行动	员工、账号、Agent 身份	要知道哪个员工、哪个 Agent、哪个账号发起动作。没有身份锚点，后续控制和追责会失去起点。
在哪行动	终端、网络、运行环境、风险态势	同一个工具在受管终端、非受管终端、办公网、外网和高风险网络中的可信度不同。
能调什么	MCP、Skill、脚本、Shell、API、插件	工具边界决定 Agent 的行动半径。越多工具可调，越需要分级、审批、隔离和阻断。
能碰什么数据	文件、代码、凭据、剪贴板、文档、业务数据	数据边界决定泄漏和合规风险。敏感数据需要识别、分级、阻断、脱敏和留痕。
做过什么	日志、审计、报表、责任链	出事后要能还原从任务到工具调用、数据触达和外发动作的完整链路。

表 1: 办公网 Agent 治理五问的对象和含义。

五问的压缩记忆

身份回答“谁”，环境回答“在哪”，工具回答“能调什么”，数据回答“能碰什么”，审计回答“做过什么”。这五个问题拼在一起，才形成可治理的 Agent 行动画像。

3.2 形式化理解：一次 Agent 行动事件

为了把五问变成工程对象，可以把一次 Agent 行动抽象成一个事件元组：

$$E = (u, a, e, t, d, l)$$

- E : 一次可记录、可判断、可审计的 Agent 行动事件。
- u : 用户或员工身份，包括账号、组织、角色和审批状态。
- a : Agent 或工具身份，包括应用、插件、进程、版本和来源。
- e : 环境上下文，包括终端状态、网络位置、设备合规状态和风险等级。
- t : 被调用的工具能力，包括 MCP、Skill、脚本、Shell 命令和 API。
- d : 被触达的数据对象，包括文件、代码、凭据、文档、剪贴板和业务数据。
- l : 日志和责任链证据，包括调用记录、进程链、网络流量、拦截记录和审计报表。

这个元组的实际意义很强。若企业只记录 u 和 e ，它能判断谁在什么终端上登录。若再记录 a 、 t 和 d ，它就能判断某个 Agent 在什么环境下调用了什么工具、碰了什么数据。若 l 也足够完整，事后复盘才有证据基础。

3.3 五问与办公网资产盘点

王亚林特别强调，很多 Agent 工具过去没有进入资产登记范围。它们可能是 GUI 客户端、浏览器插件、IDE 插件、本地进程、命令行工具，也可能是二次开发后的内部工具。安全团队如果不知道这些工具存在，后面的权限、数据和责任链治理就很难展开。

未知资产是治理地基问题

Shadow AI 工具、浏览器插件、IDE 插件、本地脚本和未登记 MCP 服务都是“看不见”的资产。安全团队看不见资产时，准入策略、DLP 策略、EDR 规则和审计报表会出现盲区。治理的第一步应当是资产发现和身份绑定。

3.4 本章小结

治理五问把 Agent 安全从抽象担忧转换为工程对象：身份、环境、工具、数据和审计。只要五问中的任意一问缺失，治理闭环就会出现断点；五问全部连上，企业才能判断 Agent 行动是否可信、是否越界、是否可追责。

4 腾讯 IOA 三层治理闭环

演讲的中段把五问落到腾讯 IOA 的治理方案上。整体架构可概括为三层：事前准入、事中控制、事后溯源。它们分别对应使用前、运行中和使用后的安全状态。



图 4: 腾讯 IOA 三层治理架构：把 Agent 行动链纳入办公网安全体系。⁴

⁴ 视频画面时间区间：01:43:38–01:45:29。

4.1 第一层：事前准入

事前准入解决“谁在行动”和“在哪行动”。它需要识别企业内有哪些 Agent、哪些员工可以使用、运行在哪些终端上、终端是否合规、网络位置是否可信、是否通过审批。演讲中给出的核心表达是：Agent 身份乘以终端环境，决定准入条件。

准入的本质

准入超出简单的软件安装白名单。更准确地说，准入是把 Agent 身份、员工账号、终端状态、网络位置和审批结果合成一个条件判断。只有满足条件的组合，才允许访问指定网段、资源和能力。

这一层在办公网里很关键。比如同一个代码助手，在研发受管终端上可能允许访问内部代码仓；在个人设备上应限制访问；在高风险网络下还应降低权限或触发二次确认。准入控制提供的是第一道结构性边界。

4.2 第二层：事中控制

事中控制解决“能调什么”和“能碰什么数据”。Agent 运行时，安全团队要知道它调用了哪些 MCP、Skill、脚本、Shell 命令、PowerShell 命令和 API；同时还要知道它触达了哪些文件、代码、凭据、剪贴板内容和业务数据。



图 5：工具、数据与审计：用产品证据把控制链闭合。⁵

这一层需要多种能力协同：进程识别用于判断哪个程序在行动；命令识别用于发现高危 Shell、PowerShell 或脚本行为；DLP 用于识别和阻断敏感数据外发；沙箱或隔离能力用于限制高风险工具的运行边界；策略引擎用于把员工、终端、工具、数据等级和动作类型关联起来。

⁵ 视频画面时间区间：01:42:08–01:43:22。

DLP 与 EDR 的分工

DLP 更关心“数据是什么、能不能发、发到哪里”。EDR 更关心“哪个进程做了什么、命令链路怎样、是否存在威胁行为”。Agent 场景需要二者协同，因为一次风险事件往往同时包含进程动作和敏感数据流动。

4.3 第三层：事后溯源

事后溯源解决“做过什么”。过去的终端审计常常聚焦账号、终端和网络。Agent 场景还需要加入进程级、工具级、插件级和交互级证据。例如：哪个 Agent 进程读了哪个文件、调用了哪个工具、把哪些内容发往哪里、触发了哪条 DLP 或 EDR 规则、最终产生了什么业务动作。

如果日志只停留在账号登录层面，就难以解释 Agent 的真实动作。若日志覆盖进程、命令、文件、网络、工具调用和拦截证据，安全团队才能把事件从“发现异常”推进到“还原路径、定位责任、修复策略”。

4.4 三层闭环图

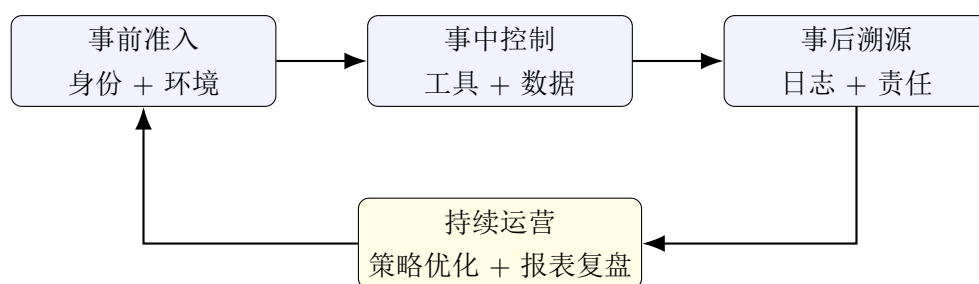


图 6: 从准入、控制、溯源到持续运营的闭环。

4.5 本章小结

腾讯 IOA 的三层治理把五问放进生命周期：事前管准入，事中管工具和数据，事后管溯源和审计。它的关键点在于整合已有办公网安全能力，例如桌面管理、终端管控、DLP、EDR、沙箱和审计报表，让 Agent 行动链进入统一治理体系。

5 实践案例：一次 AI Agent 风险事件怎样被发现、阻断和追溯

演讲中的案例来自药企办公场景。医药相关业务经常处理患者信息、用药信息、客户资料、报表和内部文档。员工使用 Agent 工具处理表格、汇总材料、生成页面或理解上下文时，可能把敏感文件拖入 Agent，或把敏感内容复制粘贴给外部模型。

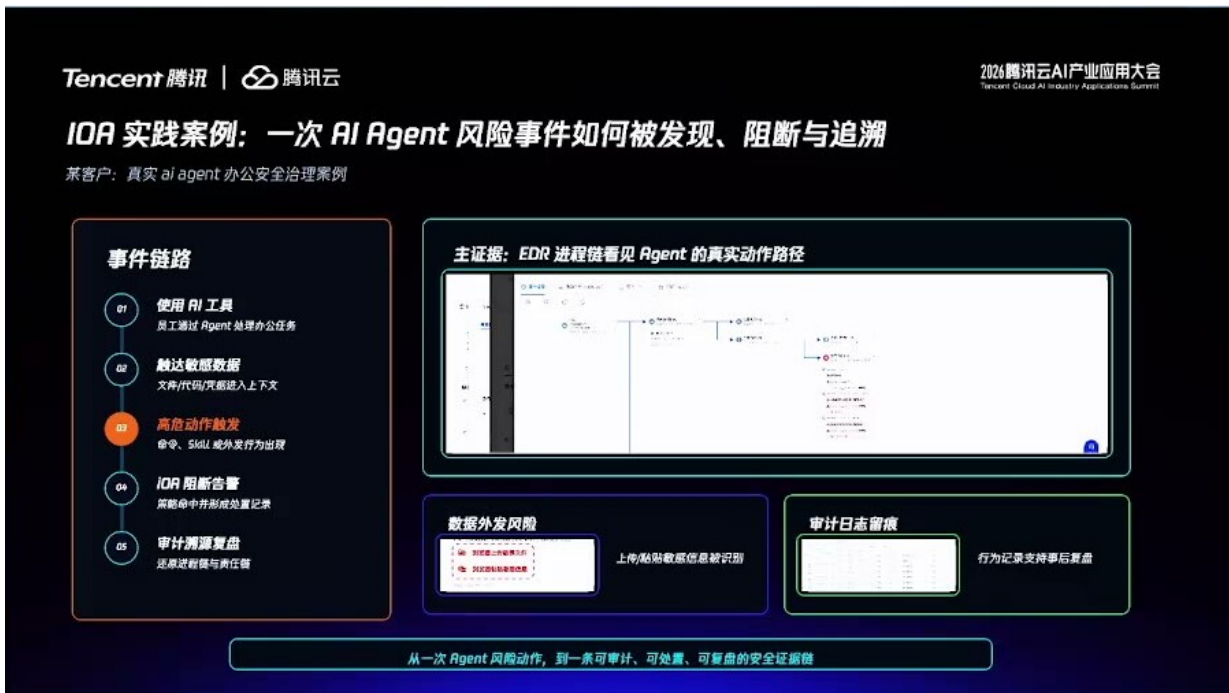


图 7: IOA 实践案例：一次 AI Agent 风险事件如何被发现、阻断与追溯。⁶

5.1 事件链路

案例中的风险链路大致可以拆成五步。第一，员工使用 AI 工具处理办公任务。第二，员工把敏感文件或上下文数据拖入 Agent。第三，Agent 或相关工具准备把内容发给模型或外部服务。第四，DLP 或终端侧策略识别出个人敏感信息、内部文档或高价值数据。第五，系统执行阻断、告警和审计留痕。

这条链路体现了前文的五问：员工和 Agent 身份回答“谁在行动”，终端和网络回答“在哪行动”，AI 工具和外部模型回答“能调什么”，患者信息和报表回答“能碰什么数据”，拦截记录和日志回答“做过什么”。

案例的治理价值

这个案例的重点在于运行时识别和阻断。企业只在事后看报表，敏感数据可能已经离开边界。运行中完成检测、分级、阻断和留痕，才能把损害控制在动作发生前后很短的窗口内。

5.2 为什么敏感数据场景更难

敏感数据治理难在三个方面。第一，数据形态多样：Excel、CSV、Word、PDF、截图、剪贴板文本、代码片段和压缩包都可能携带敏感信息。第二，通道复杂：网页、客户端、浏览器插件、IDE 插件、MCP 服务和 API 都可能成为外发路径。第三，业务有正当需求：员工确实需要用 AI 提升效率，安全策略过硬会造成绕行，策略过松会产生泄漏。

⁶ 视频画面时间区间：01:47:00–01:49:07。

策略过粗会产生两种坏结果

若企业简单封禁所有 AI 工具，业务人员会寻找影子通道。若企业放开所有工具和数据，敏感信息会进入不可控环境。更稳妥的路线是分人群、分工具、分数据等级、分终端环境和分动作类型做策略。

5.3 本章小结

药企案例说明，Agent 风险既来自模型回答错误，也来自员工把敏感数据交给工具后的外发链路。有效治理需要在运行时识别工具、识别数据、判断动作、阻断高风险路径，并把证据沉淀为可审计链路。

6 30 天落地路线：从可见到可治理

演讲最后给出一个务实路线：企业级智能体治理不必一开始就做成大而全的工程。更可行的方式是从试点人群、高风险工具和高价值数据开始，在 30 天左右形成初始闭环，再逐步扩大覆盖。



图 8: 落地路线：30 天从“可用”纳入“可治理”。⁷

6.1 0-10 天：先看得见

第一阶段目标是资产盘点和范围识别。企业需要知道哪些员工在用 Agent，哪些工具、插件、IDE、浏览器扩展和本地进程属于智能体相关能力，哪些账号和终端参与了这些行为，哪些数据范围和业务场景风险最高。

⁷ 视频画面时间区间：01:49:09-01:50:24。

这一阶段的输出应包括：Agent 资产清单、高风险工具清单、试点人群清单、关键数据范围、主要外发通道、终端覆盖率和初始风险分级。没有这些清单，后续策略会缺少对象。

6.2 11–20 天：再管得住

第二阶段目标是建立准入和阻断策略。安全团队应把高风险 Agent 工具纳入审批，把受管终端作为基本条件，给不同人群配置不同工具边界，建立 DLP 策略，识别代码、凭据、内部文档和个人敏感信息，并对高危命令、异常进程和可疑外发行为做监测。

这里的关键是逐步上线策略。先对高价值数据和高风险通道做强控制，再对一般数据和普通工具做提示、审计或低强度限制。这样可以降低业务冲击，也更容易通过运营数据修正误报。

6.3 21–30 天：最后追得回

第三阶段目标是把审计和运营报表跑起来。企业需要把账号、终端、进程、工具调用、文件访问、网络连接、DLP 告警、EDR 告警和处置结果关联起来，形成能复盘的事件视图。

这一阶段的输出应包括：风险事件看板、拦截和放行统计、策略命中明细、误报反馈、重点人群报表、敏感数据外发趋势、审计链路样例和下一轮优化计划。

30 天路线的直觉

这条路线像给一个 Python 项目加安全工程。第一周先 inventory：找出依赖、入口、配置和秘密；第二周加 guardrail：限制危险函数、网络出口和敏感文件；第三周加 observability：日志、指标、追踪和告警。Agent 治理也遵循这个节奏：先可见，再可控，最后可运营。

6.4 容易漏掉的未知问题

落地时要提前补齐的盲点

企业还需要关注浏览器插件、IDE 插件、个人账号登录企业终端、海外模型调用、模型数据驻留、剪贴板外发、截图外发、压缩包外发、MCP 服务来源、插件自动更新、例外审批、误报申诉、员工培训和日志保留周期。这些问题经常在试点后期暴露，提前列入清单可以减少返工。

6.5 本章小结

30 天路线的核心是缩小第一步：先选试点人群、高风险工具和高价值数据，把资产、策略和审计跑通，再扩大范围。治理效果来自持续运营，不能依赖一次性上线。

7 总结与延伸

王亚林在结尾给出的判断很直接：Agent 会更深入地进入办公网。企业讨论的重心应从“要不要用”转向“能不能在合理安全框架内可信、可控、可运营地用起来”。办公网相比云上环境更贴近员工日常操作、终端文件、剪贴板、浏览器、IDE、内部文档和凭据，因此 Agent 的渗透会更彻底，治理也会更贴近终端和行为链。

7.1 演讲核心压缩

- 第一，安全对象发生变化。办公网安全从保护人访问系统，扩展为保护 Agent 代人执行任务的行动链。
- 第二，治理问题需要拆解。五问把治理对象拆成身份、环境、工具、数据和审计，避免“Agent 风险”停留在口号层面。
- 第三，治理能力需要闭环。事前准入回答谁能用、在哪用；事中控制回答能调什么、能碰什么；事后溯源回答发生了什么、怎样复盘。
- 第四，落地应从小范围开始。先选择试点人群、高危工具和高价值数据，30 天内形成可见、可控、可追溯的初始闭环，再通过运营报表扩展治理范围。

7.2 对企业安全团队的启发

- 企业若已经有终端管理、DLP、EDR、准入和审计能力，应优先思考怎样把 Agent 纳入现有体系，减少孤立工具堆叠。Agent 治理的关键在于让已有控制面覆盖新的行动主体和行动链路。
- 企业若还没有成熟终端安全体系，Agent 会把短板放大。账号权限过宽、终端资产不清、敏感数据无分级、日志不可关联、审批流程慢、例外流程混乱，这些问题在 Agent 场景里会更快暴露。

最终 takeaway

办公网 Agent 安全治理的最小闭环是：看见 Agent 资产，绑定员工和终端，限制工具和数据边界，记录进程与行为链，持续用报表修正策略。没有这个闭环，企业会在效率提升和安全失控之间反复摇摆。

7.3 下一步检查清单

检查项	建议动作
Agent 资产是否可见	盘点 GUI 客户端、浏览器插件、IDE 插件、本地进程、MCP 服务和脚本工具。
身份环境是否绑定	将员工、账号、终端状态、网络位置、审批状态和 Agent 身份关联起来。
工具边界是否分级	对 MCP、Skill、Shell、PowerShell、API 和插件做分类、审批和阻断策略。
数据分级是否可执行	识别代码、凭据、内部文档、个人信息、业务报表和高价值数据，建立 DLP 策略。
审计链路是否可还原	关联账号、终端、进程、文件、网络、工具调用、告警和处置结果。

表 2: 企业落地办公网 Agent 治理的检查清单。

7.4 最终小结

这场分享的价值在于把“Agent 安全”从抽象概念拉回办公网现场：员工、终端、工具、数据、进程、日志和运营。真正需要治理的是 Agent 代人行动后形成的连续行为链，某个单点工具只是其中一个节点。企业可以从 30 天试点开始，把 Agent 从“能用”逐步纳入“可信、可控、可追溯、可运营”的安全框架。